

[TDE] Projeto Colaborativo I

Alexandre Mendes¹, Eric Rechetelo², Henrique Papai³

¹Pontifícia Universidade Católica do Paraná (PUC-PR)

taborda.alexandre@pucpr.edu.br, eric.rechetelo@pucpr.edu.br,
henrique.papai@pucpr.edu.br

Abstract. *This article presents the modeling and security analysis of a web-based system for animal shelter management. The study provides the problem's context and the definition of user profiles (Adopter, Volunteer, and Administrator), establishing essential functional and non-functional requirements. The solution is structured around a microservices architecture. To mitigate risks, an adversary model based on the STRIDE methodology is applied. Finally, the study describes future implementation steps for future developments.*

Resumo. *Este artigo apresenta a modelagem e análise de segurança de um sistema web voltado à gestão de abrigos de animais. O trabalho apresenta a contextualização do problema e a definição dos perfis de usuário (Adotante, Voluntário e Administrador) estabelecendo requisitos funcionais e não-funcionais essenciais. A solução é estruturada em uma arquitetura de microsserviços. Para a mitigação de riscos, aplica-se o modelo de adversário baseado na metodologia STRIDE. Por fim, o estudo descreve as etapas futuras para a implementação de desenvolvimentos futuros.*

1. Descrição geral do sistema

O sistema RescueHub é uma plataforma web para a gestão de abrigos de animais, projetada para automatizar fluxos de adoção de cães e gatos. Devido ao alto volume de pedidos e à manipulação de dados, como documentos pessoais e históricos internos, o software utiliza uma arquitetura de microsserviços para assegurar escalabilidade e disponibilidade. Para o desenvolvimento da solução, a interface front-end é desenvolvida com o framework Django, que se comunica por meio de um API Gateway com um sistema de microsserviços, onde terão os serviços de autenticação, animais, catálogo, e adoções operando de forma integrada e independentes, garantindo o armazenamento isolado e seguro das informações.

2. Descrição dos usuários

O software é operado por três perfis com níveis de acesso diferentes: o Adotante, que acessa o catálogo e submete pedidos de adoção mediante upload de documentos e consentimento, o Voluntário, responsável pela manutenção dos registros dos animais e agendamentos de visitas, e o Administrador, que possui o controle total sobre a gestão de usuários, aprovação de processos e monitoramento da aplicação.

3. Requisitos funcionais

Os requisitos funcionais estabelecem as funcionalidades e serviços que o sistema de gerenciamento de abrigo de animais deve fornecer para atender às necessidades dos usuários. Esses requisitos descrevem o que o sistema deve fornecer e como deve reagir em diferentes cenários. Foram selecionados dez requisitos para a composição da arquitetura. Cada requisito é apresentado em uma tabela própria, contendo código identificador, nome, descrição e nível de prioridade (baixa, média ou alta), conforme mostra as tabelas abaixo:

Tabela 1. Requisito de Autenticação e Autorização

[RF01]	Autenticação e Autorização
Descrição	O sistema deve permitir que usuários, como adotantes, voluntários e administradores, realizem login e logout por meio do serviço de autenticação, validando credenciais e fornecendo tokens de acesso seguros para navegação.
Prioridade	Alta

Tabela 2. Requisito de Cadastro e Gestão de Animais

[RF02]	Cadastro e Gestão de Animais
Descrição	O sistema deve permitir que voluntários e administradores cadastrem, editem e atualizem cães e gatos no catálogo, incluindo informações como nome, idade estimada, porte, temperamento e histórico de saúde.
Prioridade	Alta

Tabela 3. Requisito de Visualização e Filtro do Catálogo

[RF03]	Visualização e Filtro do Catálogo
Descrição	O sistema deve fornecer uma interface para que adotantes visualizem os animais disponíveis para adoção, permitindo filtros por espécie, sexo e faixa etária por meio do Serviço de Animais e Catálogo.
Prioridade	Alta

Tabela 4. Requisito de Submissão de Pedido de Adoção

[RF04]	Submissão de Pedido de Adoção
Descrição	O sistema deve permitir que adotantes autenticados selecionem um animal disponível e iniciem formalmente uma solicitação de adoção no Serviço de Adoções.
Prioridade	Alta

Tabela 5. Requisito de Upload de Documentação do Adotante

[RF05]	Upload de Documentação do Adotante
Descrição	O sistema deve permitir que o adotante anexe os documentos obrigatórios, como RG, CPF e comprovante de residência, em formato PDF durante o processo de solicitação de adoção.
Prioridade	Alta

Tabela 6. Requisito de Controle de Status do Processo de Adoção

[RF06]	Controle de Status do Processo de Adoção
Descrição	O sistema deve permitir que voluntários e administradores alterem o status das solicitações de adoção, como Pendente, Em Análise, Aprovado e rejeitado, garantindo a atualização dessas informações no banco de dados do Serviço de Adoções.
Prioridade	Alta

Tabela 7. Requisito de Gerenciamento de Conteúdo de Mídia (Fotos)

[RF07]	Gerenciamento de Conteúdo de Mídia (Fotos)
Descrição	O sistema deve permitir que administradores insiram, alterem ou removam fotos dos animais para exibição no catálogo público da plataforma.
Prioridade	Alta

Tabela 8. Requisito de Painel de Acompanhamento do Adotante

[RF08]	Painel de Acompanhamento do Adotante
Descrição	O sistema deve oferecer uma área restrita para que o adotante visualize o andamento de suas solicitações de adoção e o histórico de interações relacionadas ao processo junto ao abrigo.
Prioridade	Alta

Tabela 9. Requisito de Gestão de Perfis de Usuários

[RF09]	Gestão de Perfis de Usuários
Descrição	O sistema deve permitir que administradores gerenciem os perfis e permissões dos usuários internos, como voluntários, definindo quais ações cada perfil pode executar, como aprovar adoções ou apenas editar o catálogo.
Prioridade	Alta

Tabela 10. Requisito de Rastreabilidade e Auditoria de Ações

[RF10]	Rastreabilidade e Auditoria de Ações
Descrição	O sistema deve registrar logs das mudanças realizadas em processos de aprovação ou rejeição de adoções, identificando o usuário responsável por cada ação para fins de auditoria e rastreabilidade.
Prioridade	Alta

4. Requisitos não-funcionais

Os requisitos não-funcionais descrevem as condições sob as quais o sistema operará, atuando como restrições sobre os serviços ou funções oferecidas. Foram selecionados três requisitos para a composição da arquitetura. Cada requisito é apresentado em uma tabela própria, contendo código identificador, nome, categoria, descrição e nível de prioridade (baixa, média ou alta), conforme mostra as tabelas abaixo:

Tabela 11. Requisito de Backups

[RNF01]	Backups
Categoria	Confiabilidade
Descrição	O sistema deve realizar backups diários criptografados de todos os dados e arquivos armazenados.
Prioridade	Alta

Tabela 12. Requisito de Políticas de Senhas

[RNF02]	Políticas de senhas
Categoria	Segurança
Descrição	O sistema deve exigir que usuários utilizem senhas com pelo menos, 12 caracteres, incluindo letras maiúsculas, minúsculas, números e caracteres especiais.
Prioridade	Alta

Tabela 13. Requisito de Proteção contra SQL Injection

[RNF03]	Proteção contra SQLi
Categoria	Segurança
Descrição	Todas as interações com o banco de dados devem utilizar prepared statements, impedindo que o usuário concatene strings no seu input.
Prioridade	Alta

5. Diagrama da arquitetura baseada em microsserviços

A arquitetura do sistema é fundamentada em microsserviços, com cada componente isolado em contêineres Docker. A Figura 1 ilustra a estrutura da arquitetura, detalhando a comunicação entre a interface de usuário, o API Gateway e os serviços de back-end por meio de APIs REST.

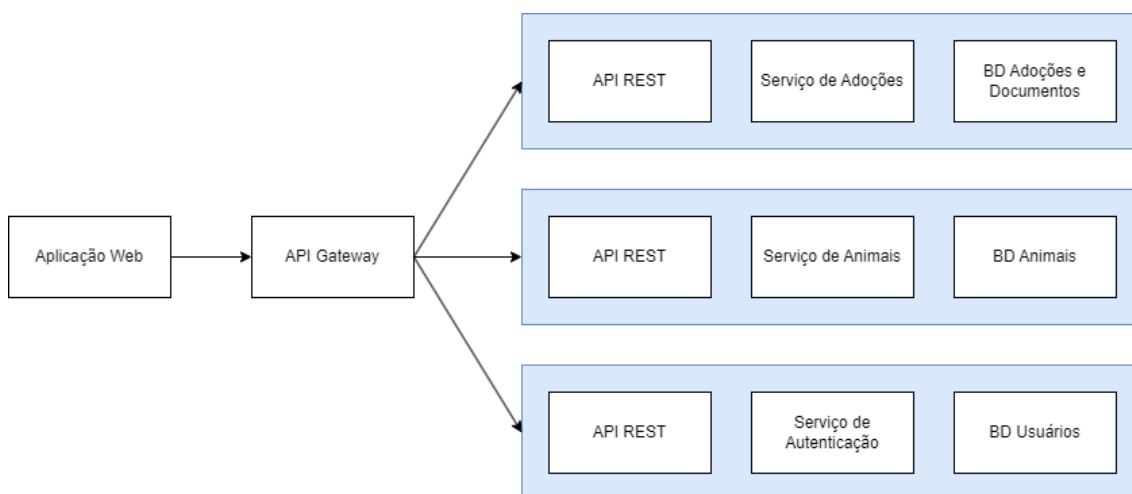


Figura 1. Diagrama de arquitetura

Aplicação Web: Interface responsável por fornecer o front-end para adotantes e usuários internos. É implementada utilizando o framework Django na linguagem Python 3.12;

API Gateway: Ponto de entrada para todas as requisições da aplicação web, atuando como intermediário e executor de políticas de segurança, como a validação de autenticação. Será implementado com Django em python.

Serviço de Autenticação: Fornece as funcionalidades para autenticação dos usuários, tanto adotante, voluntário e administrador. Esse serviço é acessível através API REST, implementada em Django no python, e comunica-se com o BD Usuários;

Serviço de Animais e Catálogo: Fornece as funcionalidades para o cadastro de animais, inserção de fotos e consulta ao catálogo de animais para adoção. Implementado com Django utilizando python, comunica-se com o BD Animais;

Serviço de Adoções: Gerencia o fluxo de aprovação, o upload de documentos e a rastreabilidade das solicitações. Este serviço é acessível via API REST e armazena as informações de documentos no BD Adoções;

Bancos de Dados Usuários, Animais e Adoções: São três bancos para armazenamento das informações que atuam como instancias independentes. Os bancos são implementados em PostgreSQL.

6. Modelo do adversário usando STRIDE

6.1 Modelo do Adversário

Consideramos um adversário com motivação para ganho ilícito de dados, possuindo conhecimentos intermediários em segurança web.

6.2 Características

- Pontos fortes: Possui experiência para realizar varreduras em busca de falhas na aplicação e entende bem o funcionamento de APIs REST.
- Pontos fracos: Pelo fato de possuir conhecimento intermediário, o adversário geralmente depende de ferramentas automatizadas, deixando clara sua atividade nos logs.

6.3 Motivação

Possui motivação financeira para venda de dados pessoais.

6.4 Medidas preventivas

- Limites de Requisições: Implementar limites de requisições no API Gateway para mitigar ataques de força bruta e DoS.
- Tratar campos: Sanitizar os campos de entrada do usuário para prevenir SQL Injection nos bancos de dados.
- Monitorar Logs: Centralizar logs de acesso para detectar atividades maliciosas na aplicação.
- Hardening: Implementar controle de acesso às contas de adotante, voluntário e administrador, e garantir que os dados sensíveis estejam criptografados dentro dos bancos de dados.
- Treinamento para os Voluntários: Treinar os voluntários a identificar tentativas de phishing.

Tabela 14. STRIDE - Aplicação Web e API Gateway

Aplicação Web e API Gateway		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	Alguém intercepta a conexão e tenta se passar pelo usuário logado usando cookie/token que foi roubado.
Tampering	Integridade	Após roubar a sessão do usuário, o atacante consegue alterar dados e requisições utilizando as permissões da vítima autenticada.
Repudiation	Não Repúdio	Após utilizar uma sessão roubada, o atacante pode negar que realizou as ações, já que as operações ficam registradas como se fossem do usuário legítimo.
Information Disclosure	Confidencialidade	O sistema exibe mensagens de erro detalhadas que acabam revelando como o back-end funciona para um atacante.
Denial of Service	Disponibilidade	Um ataque de várias tentativas de acesso que derruba o Gateway, impedindo qualquer pessoa de acessar o site.
Elevation of Privilege	Autorização	

Tabela 15. STRIDE - Microserviço de Autenticação

Microsserviço de Autenticação		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	Um atacante tenta realizar ataques de força bruta para entrar na conta de um usuário ou administrador do abrigo.
Tampering	Integridade	
Repudiation	Não Repúdio	Um usuário pode alterar a senha, e se o sistema não tiver logs da atividade, o usuário pode alegar falha no sistema ou que sua conta foi invadida para não se responsabilizar pela ação.
Information Disclosure	Confidencialidade	
Denial of Service	Disponibilidade	Um atacante pode realizar milhares de tentativas de login inválidas por segundo para sobrecarregar o serviço. Isso trava o sistema e impede que usuários legítimos acessem o sistema.
Elevation of Privilege	Autorização	

Tabela 16. STRIDE - Microsserviço de Gestão de Animais

Microsserviço de Gestão de Animais		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	
Tampering	Integridade	Um usuário mal-intencionado pode conseguir alterar as informações de um animal, como raça ou cor, sem autorização.
Repudiation	Não Repúdio	
Information Disclosure	Confidencialidade	Alguém consegue ver dados de animais que ainda não foram liberados para adoção pública.
Denial of Service	Disponibilidade	
Elevation of Privilege	Autorização	

Tabela 17. STRIDE - Microsserviço de Fluxo de Adoções

Microsserviço de Fluxo de Adoções		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	
Tampering	Integridade	O envio de documentos falsos ou a alteração de um contrato de adoção que já estava salvo no sistema.
Repudiation	Não Repúdio	Um voluntário aprova uma adoção por engano e, depois, apaga os registros de atividade. Sem os logs, ele pode negar que foi o autor da aprovação.
Information Disclosure	Confidencialidade	
Denial of Service	Disponibilidade	
Elevation of Privilege	Autorização	Um adotante comum consegue alterar o endereço do site através da URL para acessar o painel de aprovação e aprovar o próprio pedido.

Tabela 18. STRIDE - Banco de Dados

Banco de Dados		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	
Tampering	Integridade	Um invasor conseguir acesso direto ao banco e apagar o histórico de adoções para esconder uma fraude.
Repudiation	Não Repúdio	
Information Disclosure	Confidencialidade	Um atacante insere comandos SQL no campo de login e descobre o nome do banco, tabelas, colunas, nomes de usuários, senhas, etc.
Denial of Service	Disponibilidade	
Elevation of Privilege	Autorização	

6.5 DFD

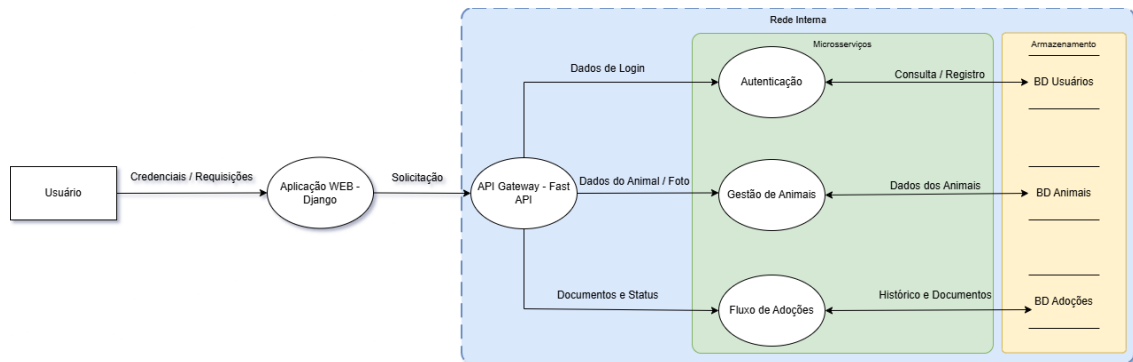


Figura 2. Diagrama de arquitetura

7. Etapas futuras

7.1 Provedor de nuvem público

Hoje, o projeto Rescuehub está rodando em computadores locais usando containers, mas um plano para o futuro é levar tudo para a AWS. Para isso, usaremos uma ferramenta chamada Terraform, que permite escrever em código como a nossa rede e os servidores devem ser criados, evitando erros que possam ocorrer nesse procedimento. Também vamos trocar os bancos de dados locais por um da Amazon RDS, em nuvem. Escolhemos essa mudança porque depender de computadores locais podem estragar ou ficar sem energia. Colocando o ambiente na nuvem, o sistema ganha segurança e fica disponível para as pessoas acessarem de qualquer lugar, com muito mais confiança e velocidade.

7.2 Implementação de SAST e DAST no desenvolvimento

Como a segurança é essencial para o DevSecOps, principalmente quando lidamos com dados pessoais, o nosso objetivo futuro é implementar testes automáticos de segurança direto no nosso fluxo de trabalho no GitHub. Para isso, vamos usar o SonarQube para fazer o SAST, que é basicamente uma varredura que analisa o código-fonte e avisa se o script está implementado de forma inadequada na aplicação. Além disso, vamos usar o OWASP ZAP para fazer o DAST, que basicamente é um teste de segurança que ataca o sistema enquanto ele está rodando para ver se encontra outras vulnerabilidades. O motivo dessa escolha que é muito mais barato achar um erro enquanto estamos programando do que descobrir um vazamento de dados depois.

7.3 Implementação de novo requisito Não Funcional

A ideia da nossa terceira etapa futura para o nosso sistema fazer a aplicação web totalmente responsiva, garantindo que adotantes e voluntários possam acessar o sistema da mesma forma e facilidade tanto em computadores quanto em celulares, oferecendo uma experiência mais fluida em qualquer navegador móvel.

7.4 Reflexos dos integrantes

- Alexandre Mendes: Durante o desenvolvimento do RescueHub, percebi na prática como a segurança precisa estar presente desde o início do projeto, e não como um ajuste feito no final. A parte que mais me chamou atenção foi a modelagem de ameaças com STRIDE. Antes disso, eu pensava em segurança de forma genérica, mas o framework me forçou a pensar como um atacante real e mapear cada ponto vulnerável do sistema. Trabalhar com microserviços também foi desafiador, pois exige uma disciplina maior na separação de responsabilidades e na comunicação entre serviços.

- Eric Rechetelo: O projeto me fez entender melhor como a arquitetura de um sistema impacta diretamente na sua segurança, além disso, dividir a aplicação em microserviços no começo parecia mais complexo, mas durante o desenvolvimento da atividade não achei tão complicado. Com relação a parte das etapas futuras também foi interessante, pois me ajudou a pensar além do que estávamos entregando e pensar em como o sistema pode evoluir.

- Henrique Papai: Durante essa parte do desenvolvimento do projeto, entendi melhor sobre a importância do fluxo de dados no sistema. Ao fazer o DFD, percebi que identificar por onde a informação passa desde o usuário até o banco de dados é o que permite identificar onde existem os riscos. Além disso, pude entender melhor como os microserviços funcionam e como o API Gateway faz a comunicação entre eles, isso me fez entender que uma arquitetura bem desenhada facilita não só o desenvolvimento, mas a implementação da segurança.

8. Referências

Papai, H. (2026) “RescueHub”, <https://github.com/HenriquePapai/RescueHub>, Abril.

REQUISITOS NÃO FUNCIONAIS AQUI PARA BATER PRINT:

[RNF01]	Backups
Categoria	Confiabilidade
Descrição	O sistema deve realizar backups diários criptografados de todos os dados e arquivos armazenados.
Prioridade	Alta

[RNF02]	Políticas de senhas
Categoria	Segurança
Descrição	O sistema deve exigir que usuários utilizem senhas com pelo menos, 12 caracteres, incluindo letras maiúsculas, minúsculas, números e caracteres especiais.
Prioridade	Alta

[RNF03]	Proteção contra SQLi
---------	----------------------

Categoria	Segurança
Descrição	Todas as interações com o banco de dados devem utilizar prepared statements, impedindo que o usuário concatene strings no seu input.
Prioridade	Alta

REQUISITOS FUNCIONAIS AQUI PARA BATER PRINT:

[RF01]	Autenticação e Autorização
Descrição	O sistema deve permitir que usuários, como adotantes, voluntários e administradores, realizem login e logout por meio do serviço de autenticação, validando credenciais e fornecendo tokens de acesso seguros para navegação.
Prioridade	Alta

[RF02]	Cadastro e Gestão de Animais
Descrição	O sistema deve permitir que voluntários e administradores cadastrem, editem e atualizem cães e gatos no catálogo, incluindo informações como nome, idade estimada, porte, temperamento e histórico de saúde.
Prioridade	Alta

[RF03]	Visualização e Filtro do Catálogo
Descrição	O sistema deve fornecer uma interface para que adotantes visualizem os animais disponíveis para adoção, permitindo filtros por espécie, sexo e faixa etária por meio do Serviço de Animais e Catálogo.
Prioridade	Alta

[RF04]	Submissão de Pedido de Adoção
Descrição	O sistema deve permitir que adotantes autenticados selecionem um animal disponível e iniciem formalmente uma solicitação de adoção no Serviço de Adoções.

Prioridade	Alta
------------	------

[RF05]	Upload de Documentação do Adotante
Descrição	O sistema deve permitir que o adotante anexe os documentos obrigatórios, como RG, CPF e comprovante de residência, em formato PDF durante o processo de solicitação de adoção.
Prioridade	Alta

[RF06]	Controle de Status do Processo de Adoção
Descrição	O sistema deve permitir que voluntários e administradores alterem o status das solicitações de adoção, como Pendente, Em Análise, Aprovado e rejeitado, garantindo a atualização dessas informações no banco de dados do Serviço de Adoções.
Prioridade	Alta

[RF07]	Gerenciamento de Conteúdo de Mídia (Fotos)
Descrição	O sistema deve permitir que administradores insiram, alterem ou removam fotos dos animais para exibição no catálogo público da plataforma.
Prioridade	Alta

[RF08]	Painel de Acompanhamento do Adotante
Descrição	O sistema deve oferecer uma área restrita para que o adotante visualize o andamento de suas solicitações de adoção e o histórico de interações relacionadas ao processo junto ao abrigo.
Prioridade	Alta

[RF09]	Gestão de Perfis de Usuários
Descrição	O sistema deve permitir que administradores gerenciem os perfis e permissões dos usuários internos, como voluntários, definindo quais ações cada perfil pode executar, como aprovar adoções ou apenas editar o catálogo.
Prioridade	Alta

[RF10]	Rastreabilidade e Auditoria de Ações
Descrição	O sistema deve registrar logs das mudanças realizadas em processos de aprovação ou rejeição de adoções, identificando o

	usuário responsável por cada ação para fins de auditoria e rastreabilidade.
Prioridade	Alta

CRIAR O MODELO DO ADVERSÁRIO USANDO STRIDE AQUI PARA BATER PRINT:

Aplicação Web e API Gateway		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	Alguém intercepta a conexão e tentar se passar pelo usuário logado usando cookie/token que foi roubado.
Tampering	Integridade	Após roubar a sessão do usuário, o atacante consegue alterar dados e requisições utilizando as permissões da vítima autenticada.
Repudiation	Não Repúdio	Após utilizar uma sessão roubada, o atacante pode negar que realizou as ações, já que as operações ficam registradas como se fossem do usuário legítimo.
Information Disclosure	Confidencialidade	O sistema exibe mensagens de erro detalhadas que acabam revelando como o back-end funciona para um atacante.
Denial of Service	Disponibilidade	Um ataque de várias tentativas de acesso que derruba o Gateway, impedindo qualquer pessoa de acessar o site.
Elevation of Privilege	Autorização	

Microsserviço de Autenticação		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	Um atacante tenta realizar ataques de força bruta para entrar na conta de um usuário ou administrador do abrigo.
Tampering	Integridade	
Repudiation	Não Repúdio	Um usuário pode alterar a senha, e se o sistema não tiver logs da atividade, o usuário pode alegar

		falha no sistema ou que sua conta foi invadida para não se responsabilizar pela ação.
Information Disclosure	Confidencialidade	
Denial of Service	Disponibilidade	Um atacante pode realizar milhares de tentativas de login inválidas por segundo para sobrecarregar o serviço. Isso trava o sistema e impede que usuários legítimos acessem o sistema.
Elevation of Privilege	Autorização	

Microserviço de Gestão de Animais		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	
Tampering	Integridade	Um usuário mal-intencionado pode conseguir alterar as informações de um animal, como raça ou cor, sem autorização.
Repudiation	Não Repúdio	
Information Disclosure	Confidencialidade	Alguém consegue ver dados de animais que ainda não foram liberados para adoção pública.
Denial of Service	Disponibilidade	
Elevation of Privilege	Autorização	

Microserviço de Fluxo de Adoções		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	
Tampering	Integridade	O envio de documentos falsos ou a alteração de um contrato de adoção que já estava salvo no sistema.
Repudiation	Não Repúdio	Um voluntário aprova uma adoção por engano e, depois, apaga os registros de

		atividade. Sem os logs, ele pode negar que foi o autor da aprovação.
Information Disclosure	Confidencialidade	
Denial of Service	Disponibilidade	
Elevation of Privilege	Autorização	Um adotante comum consegue alterar o endereço do site através da URL para acessar o painel de aprovação e aprovar o próprio pedido.

Banco de Dados		
Ameaça	Propriedade Violada	Descrição da Ameaça
Spoofing	Autenticação	
Tampering	Integridade	Um invasor conseguir acesso direto ao banco e apagar o histórico de adoções para esconder uma fraude.
Repudiation	Não Repúdio	
Information Disclosure	Confidencialidade	Um atacante insere comandos SQL no campo de login e descobre o nome do banco, tabelas, colunas, nomes de usuários, senhas, etc.
Denial of Service	Disponibilidade	
Elevation of Privilege	Autorização	